

บทที่ 2

ทฤษฎีพื้นฐานที่ใช้ในการพัฒนาระบบอันนี้พ็อต

ในหัวข้อนี้จะกล่าวถึงทฤษฎีพื้นฐานต่างๆ ที่เกี่ยวข้องในการวิจัย และพื้นฐานของระบบอันนี้พ็อตซึ่งเนื้อหาในบทนี้จะกล่าวถึงแนวคิดของอันนี้พ็อต, การทำงานของระบบตรวจจับผู้บุกรุก, การทำงานของไฟร์วอลล์, และรูปแบบการบุกรุกแบบต่างๆ ซึ่งเนื้อหาทั้งหมดนี้จำเป็นสำหรับการศึกษาและพัฒนาระบบอันนี้พ็อต

2.1 แนวคิดของอันนี้พ็อต

แนวคิดของอันนี้พ็อตคือ ต้องการทราบการกระทำ และความพยายามต่างๆ ที่ผู้บุกรุกกระทำต่อระบบ ดังนั้นเพื่อให้ได้มา จำเป็นจะต้องสร้างระบบบางอย่างให้เหล่าผู้บุกรุกได้เข้ามาและระบบต้องสามารถจับตามองได้ โดยที่ผู้บุกรุกไม่รู้ตัว ว่ากำลังโดนจับตามองอยู่ และโดยที่ไม่ส่งผลเสียใดๆ ต่อระบบจริง เปรียบเสมือนล่อหลอกให้ขโมยพยายามงัดเข้ามาในบ้าน แล้วใช้กล้องวงจรปิดถ่ายภาพไว้ทุกๆ การกระทำตั้งแต่วิธีที่ใช้ในการงัดเข้ามาในบ้าน พยายามทำอะไรบ้าง สนใจสำรวจอะไรบ้าง หรือได้นำอะไรออกไป โดยที่บ้านและของมีค่าใดๆ เป็นเพียงภาพลวงตาเท่านั้น ทำให้ไม่ต้องเสียทรัพย์สินหรือก่อให้เกิดอันตรายใดๆ ซึ่งทำให้เราสามารถเห็นวิธีที่ผู้บุกรุกใช้ ตลอดจนเครื่องมือใหม่ๆ ที่ผู้บุกรุกอาจนำมาใช้ ซึ่งเมื่อเราทราบวิธีและเครื่องมือของผู้บุกรุก ทำให้เราสามารถนำข้อมูลที่ได้ไปประยุกต์เพื่อปรับปรุงและป้องกันระบบจริงให้มีความปลอดภัยมากยิ่งขึ้น

2.2 วิวัฒนาการของอันนี้พ็อต

เริ่มแรกมีความต้องการทราบการกระทำของผู้บุกรุก เพื่อเรียนรู้วิธีการและสิ่งที่ผู้บุกรุกสนใจ โดยในยุคแรกนี้ได้เริ่มสร้างเพียงการบริการเสมือน(serviceที่จำลองขึ้นมาให้เหมือนserviceจริงๆ) หรืออาจเรียกว่าเป็นแบบ Low-interaction อันนี้พ็อตที่มีลักษณะแบบนี้จะเป็นการจำลองบริการต่างๆ ขึ้นทำให้ดูเหมือนว่ามีเครื่องที่เปิดให้บริการต่างๆ เช่น FTP เป็นต้น ซึ่งอันนี้พ็อตชนิดนี้จะมีความจำกัดในส่วนของการโต้ตอบการโจมตีของผู้บุกรุก ซึ่งการโต้ตอบของอันนี้พ็อตรูปแบบจะขึ้นอยู่กับการทำส่วนจำลองบริการและขึ้นอยู่กับระบบปฏิบัติการที่ใช้ เช่น อาจทำให้สามารถล็อกอินได้ หรือทำให้ใช้คำสั่งต่างๆ ได้เหมือนกับบริการจริงๆ ตัวอย่าง Honeypot ที่เป็นแบบ Low-interaction เช่น Specter, Honeyd และ KFSensor

ข้อดีของฮันนี่พ็อตแบบ Low-interaction นี้คือมีความยืดหยุ่นง่ายต่อการเปลี่ยนแปลงและบำรุงรักษาตัวฮันนี่พ็อต และมีอัตราเสี่ยงเล็กน้อย ซึ่งโดยทั่วไปแล้วมีระบบ Plug & Play ซึ่งจะทำให้การเปลี่ยนแปลงเป็นไปได้โดยสะดวก การจำลองบริการนั้นจะช่วยลดความเสี่ยงโดยสามารถบรรจุสิ่งที่ใช้ตอบโต้ผู้บุกรุก ผู้บุกรุกจะไม่สามารถเข้ายึดครองระบบปฏิบัติการนั้น (honeypot) เพื่อใช้ในการโจมตีผู้อื่นต่อไปได้

ข้อเสียของฮันนี่พ็อตแบบ Low-interaction นี้คือสามารถออกแบบได้เฉพาะการตรวจจับการกระทำที่ทราบอยู่แล้วเท่านั้น ซึ่งมีข้อจำกัดมากมายในการเฝ้าดูพฤติกรรมผู้บุกรุก เพราะสิ่งที่เห็นจะแค่เพียงส่วนที่เกี่ยวข้องกับserviceนั้นเท่านั้น

ต่อมาจึงมีการสร้างเป็นเครื่องให้บริการเสมือน(เสมือนเป็นเครื่องคอมพิวเตอร์ที่ทำงานจริงซึ่งจะมีเรื่องของระบบปฏิบัติการเข้ามาเกี่ยว) อาจเรียกว่าเป็นแบบ High-interaction ฮันนี่พ็อตที่มีลักษณะแบบนี้จะมีทั้งระบบปฏิบัติการ แอปพลิเคชัน และบริการจริงๆ เพื่อตอบโต้กับผู้บุกรุก นั่นคือถ้าต้องการให้มีบริการใดก็ทำการลงโปรแกรม หรือเปิดบริการต่างๆ ที่เครื่องจริงๆ อย่างเช่น ถ้าจะเปิดบริการ FTP ก็ลงโปรแกรมอย่างเช่น Ftpd เป็นต้น

ข้อดีของฮันนี่พ็อตแบบ High-interaction คือข้อมูลที่ได้จากการกระทำของผู้บุกรุกนั้นมีความครอบคลุมมากกว่าเพราะจะมีการโต้ตอบทุกอย่างที่เหมือนจริง ดังนั้นเราจึงสามารถสรุปผลข้อมูลได้จากการโจมตีจริง ระบบจะตอบโต้กับผู้บุกรุกจริงๆ เราจึงสามารถเรียนรู้ขอบเขตของพฤติกรรมของเหล่าผู้บุกรุกได้ดี และข้อดีอีกข้อหนึ่งคือฮันนี่พ็อตแบบ High-interaction นั้นไม่ได้จำลองว่าการตอบโต้กลับไปยังผู้บุกรุกว่าควรจะต้องกลับแบบใดเพราะที่นั่นใช้เป็นตัวระบบจริงที่ติดตั้งอยู่บนฮันนี่พ็อต สามารถจับตาการกระทำต่อระบบซึ่งอาจส่งผลกระทบต่อบริการที่เครื่องนั้นๆ ให้บริการอยู่ หรือข้อมูลที่ผู้บุกรุกสนใจ และทำการสำรวจหรือนำออกไป โดยจะสามารถเฝ้าดูพฤติกรรมได้ครอบคลุมกว่าแบบเดิมมาก

ข้อเสียฮันนี่พ็อตแบบ High-interaction คือการเพิ่มอัตราเสี่ยงให้กับระบบ เนื่องจากผู้บุกรุกนั้นสามารถที่อาจสามารถเข้ายึดครองเครื่องที่ทำหน้าที่เป็นฮันนี่พ็อตแล้วใช้เครื่องนั้นๆ ในการโจมตีระบบอื่นๆ ก็เป็นไปได้เช่นกัน ดังนั้นการใช้งานฮันนี่พ็อตที่เป็นแบบ High-interaction นั้นจึงต้องหาทางควบคุมพฤติกรรมของผู้บุกรุกให้อยู่ภายในขอบเขตที่เรากำหนดและไม่สามารถใช้ฮันนี่พ็อตเป็นฐานที่มั่นในการเข้าโจมตีระบบอื่นๆ ได้ ตัวอย่างของตัวฮันนี่พ็อตแบบ High-interaction คือ Honeynets เป็นต้น โดยการกระทำที่สามารถจับตาได้ในยุคนี้จะเป็นการกระทำที่ไม่มีเรื่องของการเข้ารหัสลับเข้ามาเกี่ยวข้อง เช่นการทำงานผ่านtelnetซึ่งไม่มีการเข้ารหัสข้อมูลก่อนทำการส่ง ดังนั้นเมื่อมีเทคโนโลยีหรือเครื่องมือใหม่ๆ ที่มีการเข้ารหัส เช่น SSL, SSH, SCP ก็จะสามารถดักข้อมูลได้

ต่อมาได้มีการนำเครื่องมือที่มีลักษณะของRootkits ซึ่งมีการทำงานแบบ Kernel-base tools เข้ามาใช้งานเพื่อให้สามารถเข้าถึงข้อมูลที่ทำให้การเข้ารหัส โดยที่เครื่องมือเหล่านี้ไม่ได้ไปนำข้อมูลมาถอดรหัส แต่จะเป็นการดูข้อมูลก่อนที่จะถูกเข้ารหัส(กรณีที่เป็นฝั่งส่ง) และอ่านข้อมูลหลังจากที่ถอดรหัสเรียบร้อยแล้ว(ในฝั่งรับ) ทำให้สามารถจับตาการกระทำของผู้บุกรุกได้ แม้จะใช้ SSH เข้ามายังเครื่องกับดัก ดังนั้นสิ่งที่เราสามารถบันทึกได้จะครอบคลุม พฤติกรรมของผู้บุกรุกทั้งหมด เช่น การกดkeyboard การใช้คำสั่ง การถ่ายโอนไฟล์ การนำข้อมูลเข้าออก หรือการเรียกใช้โปรแกรม ได้มีการเพิ่มคุณสมบัติในการซ่อนตัวเองไม่ให้ผู้บุกรุกตรวจพบที่กำลังทำงานอยู่ และในขณะนี้ได้เริ่มนำอันนี้เพื่อเข้ามาเป็นส่วนหนึ่งของระบบจริง นั่นคือมีการทำการคัดแยกผู้บุกรุกออกจากผู้ใช้งานทั่วไป โดยมีการจัดเป็นโครงสร้างของระบบอันนี้เพื่อขึ้น โดยประกอบขึ้นด้วยหลายๆส่วน ซึ่งทำหน้าที่ต่างกันไป เช่น Honeywall, Log server, Cage โดยแยกเครื่องกับดักออกจากเครื่องให้บริการจริง เพื่อไม่ให้เกิดการกระทำต่อเครื่องกับดักเกิดความเสียหายต่อเครื่องให้บริการจริง แต่ยังมีข้อจำกัดในการบันทึกผลการเปลี่ยนแปลงของระบบหลังจากมีการใช้คำสั่ง หรือการเรียกใช้โปรแกรม

2.3 ความรู้พื้นฐานเกี่ยวกับการบุกรุก

บุคคลที่พยายามเข้ามายังระบบโดยไม่ได้รับอนุญาตเราเรียกว่า “ผู้บุกรุก” หรือ “intruder” ซึ่ง

2.3.1 ผู้บุกรุกนั้นอาจแบ่งได้เป็น 2 ประเภทคือ

2.3.1.1 Outsider intruder (ผู้บุกรุกจากภายนอก) หมายถึง บุคคลภายนอกเครือข่ายที่พยายามเจาะเข้ามาในระบบหรือพยายามโจมตีระบบจากภายนอก เช่น การเจาะเข้ามายังเครื่องเว็บเซิร์ฟเวอร์แล้วเปลี่ยนหน้าเว็บไซต์ของเรา เป็นต้น ซึ่งการบุกรุกนี้อาจมาจากอินเทอร์เน็ต, การ dial-up หรือการบุกรุกเข้าไปยังเครือข่ายของคู่ค้าแล้วเชื่อมต่อมายังเครือข่ายของเรา

2.3.1.2 Insider intruder (ผู้บุกรุกจากภายใน) หมายถึง บุคคลภายในเครือข่าย รวมทั้งผู้ใช้ที่ใช้สิทธิ์ในทางที่ผิด หรือการลักลอบใช้สิทธิ์ของผู้ใช้คนอื่นๆ ที่มีสิทธิ์เหนือกว่า

2.3.2 เส้นทางที่ผู้บุกรุกสามารถเข้าสู่ระบบมี 3 ทางหลักๆ คือ

2.3.2.1 Physical Intrusion คือการที่ผู้บุกรุกทำการเชื่อมต่อทางกายภาพกับเครื่องหรือระบบเครือข่ายเช่น มานั่งหน้าเครื่อง หรือนำเครื่องมาเสียบสายแลน เป็นต้น

2.3.2.2 System Intrusion คือการที่ผู้บุกรุกมีรหัสผ่านเรียบร้อยแล้วแต่เป็นรหัสผ่านของบัญชีผู้ใช้ที่มีสิทธิ์ต่ำ ถ้าระบบไม่ได้มีการอัปเดตแพทช์ ผู้บุกรุกจะใช้ช่องโหว่ของระบบในการเข้าครอบครองสิทธิ์ของผู้ดูแลระบบได้

2.3.2.3 Remote Intrusion ผู้บุกรุกพยายามที่จะเจาะเข้าสู่ระบบข้ามเครือข่าย ซึ่งผู้บุกรุกจะไม่มีสิทธิ์ใดๆ เลยบนระบบเครือข่ายนั้น

2.3.3 ตัวอย่างการโจมตีระบบ

2.3.3.1 IP spoofing เป็นเทคนิคที่ใช้เพื่อให้ผู้ที่ไม่มีสิทธิ์เข้ามายังคอมพิวเตอร์ได้โดยผู้บุกรุกจะทำการส่งข้อความไปยังคอมพิวเตอร์ต่างๆ โดยหลอกว่าข้อความนั้นมาจากไอพีแอดเดรสที่เป็นที่น่าเชื่อถือ โดยอาจมีวิธีการโจมตีแตกต่างกันไปดังต่อไปนี้

1. Non-blind spoofing เป็นการโจมตีที่เกิดขึ้นได้เมื่อผู้บุกรุกอยู่บนชั้นเน็ตเดียวกันกับเครื่องเป้าหมายซึ่งผู้บุกรุกสามารถมองเห็นลำดับ sequence และ acknowledgement ของแพ็กเก็ตต่างๆ ได้ เมื่อผู้บุกรุกรู้ลำดับของแพ็กเก็ตซึ่งอาจทำได้โดยการใส่โปรแกรมดักจับแพ็กเก็ตที่วิ่งไปมาอยู่ในเครือข่ายแล้วนำมาพิจารณาแล้ว ผู้บุกรุกสามารถทำ session hijacking ได้จากนั้นผู้บุกรุกอาจทำการดักเอาส่วนของการยืนยันตนต่างๆ ที่ใช้ในการสถาปนาเชื่อมต่อไว้ ทำให้การสถาปนาเชื่อมต่อนั้นล้มเหลว จากนั้นจึงทำการสถาปนาการเชื่อมต่อขึ้นโดยการแก้ไข sequence และ acknowledgement number ให้ตรงกับเครื่องของผู้บุกรุกก็ถือว่าการโจมตีนี้ทำได้สำเร็จ.

2. Blind spoofing เป็นการโจมตีที่เกิดขึ้นจากภายนอกซึ่งผู้บุกรุกไม่อาจรู้ลำดับ sequence และ acknowledgement ดังนั้นผู้บุกรุกจึงพยายามส่งแพ็กเก็ตจำนวนมากไปยังเครื่องเป้าหมายอย่างสม่ำเสมอตามลำดับของเลข sequence ที่ส่งขึ้นมา แต่ในปัจจุบันนี้ระบบปฏิบัติการได้มีการพัฒนาเรื่องของการสุ่มเลข sequence ทำให้การคาดเดาให้ถูกต้องนั้นเป็นไปได้ยาก แต่ถึงอย่างไรก็ตามถ้าเลข sequence ที่ผู้บุกรุกส่งขึ้นมานั้นถูกต้องข้อมูลจากเครื่องผู้บุกรุกก็จะถูกส่งไปยังเครื่องเป้าหมายได้เช่นกัน

3. Man in the Middle Attack เรียกได้อีกอย่างหนึ่งว่า connection hijacking ซึ่งการโจมตีแบบนี้จะเป็นการเข้าไปขัดขวางการสื่อสารระหว่างเครื่องโฮสต์ 2 เครื่องและเข้าควบคุมการสื่อสารเพื่อสลับเปลี่ยนแก้ไข หรือเพิ่มข้อมูลที่เครื่องทั้ง 2 ส่งถึงกันได้ โดยการที่ผู้บุกรุกจะทำเช่นนี้ได้ผู้บุกรุกเองต้องอยู่ในสถานที่เดียวกับเครื่องทั้ง 2 เครื่องที่ติดต่อกันโดยหัวใจหลักของการโจมตีแบบนี้คือการทำ

ให้การติดต่อระหว่างเครื่องโฮสต์ทั้ง 2 เครื่องอยู่ในสถานะที่เรียกว่า “desynchronized” นั่นคือการทำ
ให้เลขลำดับ sequence ของแพ็กเก็ตที่ได้รับไม่ตรงกับเลขลำดับ sequence ที่ต้องการนั่นเอง

4. Denial of Service Attack คือ IP spoofing ที่ใช้บ่อยที่สุดในการโจมตีแบบ denial of service
หรือ DoS ซึ่งผู้บุกรุกจะทำการใช้แบนวิดท์และทรัพยากรเครือข่ายให้หมดไปโดยการส่งแพ็กเก็ตจําน
วนมากเท่าที่จะทำได้ไปยังเครื่องเป้าหมายในเวลาอันสั้น โดยผู้บุกรุกจะทำการเปลี่ยนไอพีต้นทางไป
เรื่อยเพื่อทำให้การหยุด DoS ทำได้ยากยิ่งขึ้น

2.3.3.2 ICMP Smurfing เป็นของโปรแกรมอัตโนมัติที่จะทำการโจมตีเครือข่ายโดยใช้ไอพี
บรอดคาสต์ ซึ่ง Smurf และโปรแกรมที่มีลักษณะคล้ายๆ กันนี้สามารถทำให้บางส่วนของเครือข่าย
ไม่สามารถทำงานได้ โดยทำให้โหนดต่างๆ จะคอยแลกเปลี่ยนข้อมูลเกี่ยวกับระบบเครือข่ายโดยใช้
ICMP อยู่ตลอดเวลา

โปรแกรม Smurf จะสร้างแพ็กเก็ตที่มีไอพีต้นทางเป็นเครื่องเป้าหมายโดยแพ็กเก็ตนั้นจะ
บรรจุ ICMP ping message เอาไว้ซึ่งมีแอดเดรสปลายทางเป็นไอพีบรอดคาสต์ นั่นก็หมายถึงว่าทุกๆ
ไอพีแอดเดรสในเครือข่ายจะได้รับแพ็กเก็ตนี้ ซึ่งเมื่อเครื่องโฮสต์ส่วนใหญ่ได้รับแพ็กเก็ตดังกล่าวจะ
ทำการตอบกลับด้วย ICMP echo reply ทำให้มีแพ็กเก็ตจํานวนมากกลับไปยังเครื่องเป้าหมายซึ่งถ้าการ
ping มีมากพอก็อาจเป็นผลทำให้เครือข่ายไม่สามารถใช้งานได้

2.4 ความรู้พื้นฐานเกี่ยวกับไฟร์วอลล์

ไฟร์วอลล์นั้นเป็นเครื่องมือที่ใช้ในการป้องกันการบุกรุกหรืออาจใช้เป็นเครื่องมือในการ
จัดสรร

การใช้ทรัพยากรของระบบเครือข่ายก็ได้

2.4.1 คุณสมบัติทั่วไปของไฟร์วอลล์

ไฟร์วอลล์เป็นเครื่องมือรักษาความปลอดภัยที่ทำงานในเชิงป้องกัน ซึ่งทำหน้าที่ในการควบคุม
การเข้าถึงระบบเครือข่าย โดยอาศัยกฎเป็นพื้นฐาน (Rule based) สำหรับคุณสมบัติแต่ละอย่างของไฟร์
วอลล์มีรายละเอียดดังนี้

2.4.1.1 การป้องกัน (Protect)

ไฟร์วอลล์เป็นเครื่องมือที่ใช้งานในเชิงป้องกัน โดยชั้นข้อมูลที่ผ่านได้นั้น จะต้องเป็นชั้น

ข้อมูลที่ไฟร์วอลล์เห็นว่ามีความปลอดภัย ขึ้นข้อมูลที่ไฟร์วอลล์เห็นว่าไม่ปลอดภัยหรืออาจจะนำมาซึ่งความไม่ปลอดภัยก็จะถูกกักจัด คือไม่ส่งต่อ โดยการที่ไฟร์วอลล์จะตัดสินใจว่าขึ้นข้อมูลใดปลอดภัยและขึ้นข้อมูลใดไม่ปลอดภัยนั้นจะขึ้นอยู่กับกฎของผู้ดูแลไฟร์วอลล์ เป็นผู้กำหนดไว้ล่วงหน้า ซึ่งเงื่อนไขของกฎเหล่านี้เองทำให้ไฟร์วอลล์สามารถป้องกันขึ้นข้อมูลที่จะส่งผลร้ายไม่ให้ผ่านเข้าไปถึงเครือข่ายคอมพิวเตอร์ได้

2.4.1.2 ควบคุมการเข้าถึง (Access Control)

การเข้าถึง หมายถึงการที่เครื่องใดเครื่องหนึ่งนั้นสามารถสื่อสารข้อมูลที่ต้องการไปยังเครื่องปลายทางได้สำเร็จ การเข้าถึงในแต่ละระดับจะมีวิธีการแตกต่างกันออกไป ทำให้การควบคุมการเข้าถึงสำหรับแต่ละระดับแตกต่างกันออกไปด้วย ไฟร์วอลล์เองจึงต้องมีการทำงานหลายลักษณะตามวิธีที่ไฟร์วอลล์ใช้ควบคุมการเข้าถึง

2.4.1.3 กฎพื้นฐาน (Rule Based)

ไฟร์วอลล์จะควบคุมการเข้าถึงโดยอาศัยหลักการเปรียบเทียบคุณสมบัติของขึ้นข้อมูลที่จะผ่านไฟร์วอลล์กับกฎของการเข้าถึงที่ได้กำหนดไว้ หากพบว่าไม่มีกฎที่ห้ามไว้ก็จะอนุญาตให้ขึ้นข้อมูลนั้นผ่านได้ หากมีกฎที่ห้ามไว้ขึ้นข้อมูลนั้นก็จะถูกสกัดกั้นไว้ด้วยวิธีใดวิธีหนึ่ง

2.4.2 สเตตฟูลอินสเปกชันไฟร์วอลล์ (Stateful Inspection Firewall)

การสื่อสารโดยทั่วไปจะเป็นการสื่อสารแบบต่อเนื่อง ได้ตอบกันไปมาระหว่างผู้รับและผู้ส่ง อยู่เสมอ โปรโตคอลที่อยู่ในชั้นที่สูงกว่าอินเทอร์เน็ตเลเยอร์ ไม่ว่าจะเป็นทรานสปอร์ตอย่างเช่น ทีซีพี, ยูดีพี หรือเลยไปถึงแอปพลิเคชันเลเยอร์ เช่น เอฟทีพี, เอชทีทีพี, เอสเอ็มทีพี ล้วนแล้วแต่จะต้องมีสถานะของการสื่อสาร (State) เสมอ สถานะนี้จะทำให้ทั้งสองฝั่งสามารถสื่อสารกันได้อย่างต่อเนื่อง คือทราบว่าตอนนี้กำลังอยู่ ณ จุดใดและจะต้องส่งหรือรับข้อมูลใดเป็นลำดับต่อไป

2.4.3 ความแตกต่างของการพิจารณาข้อมูลแบบแพ็คเก็ตไฟลเตอร์ริงกับแบบสเตตฟูล

อันที่จริงสองเรื่องนี้ได้ขัดแย้งกันแต่ประการใด แพ็คเก็ตนั้นเป็นการสื่อสารที่เป็นส่วนย่อยของการสื่อสารทั้งหมด ผลของการสื่อสารข้อมูลก็คือผลรวมของการสื่อสารข้อมูลหลายๆ แพ็คเก็ตนั่นเอง แต่อย่างไรก็ตามการไฟลเตอร์หรือกรอง โดยพิจารณาทีละแพ็คเก็ตของทุกแพ็คเก็ตที่ผ่านเข้าออกนั้นอาจจะมีผลลัพธ์แตกต่างจากการไฟลเตอร์ของในแบบที่สองสถานะและภาพรวมหรือที่

เรียกว่าสเตตฟูล (Stateful) หากเปรียบเทียบการพิจารณาข้อมูลครั้งละแพ็กเก็ตกับการพิจารณาแบบสเตตฟูลแล้ว ตัวอย่างที่น่าจะช่วยให้เข้าใจได้ง่ายขึ้นคือ

เปรียบเทียบการสื่อสารข้อมูลทั้งหมดเสมือนภาพยนตร์ แพ็กเก็ตก็จะหมายถึงภาพนิ่งแต่ละภาพที่นำมาต่อรวมกันแล้วเปิดดูอย่างรวดเร็ว ภาพนิ่งเหล่านั้นจะกลายเป็นภาพเคลื่อนไหว ดังนั้นการพิจารณาแพ็กเก็ตก็จะเป็นเสมือนการดูภาพนิ่งทีละภาพ แต่จะไม่สามารถเห็นเซอร์เนือเรื่องซึ่งเป็นสิ่งที่เกิดขึ้นจากความสัมพันธ์ของภาพหลายๆ ภาพได้มีโอกาสเป็นไปได้ว่ากิจกรรมบางชนิดที่หากดูเป็นภาพนิ่งแล้วจะไม่รู้สึกว่ามีสิ่งใดที่ไม่เหมาะสม แต่หากนำภาพนิ่งมาดูอย่างต่อเนื่องเป็นภาพเคลื่อนไหวแล้วก็จะอาจจะเป็นสิ่งที่ไม่พึงปรารถนาที่จะให้ปรากฏบนภาพยนตร์ก็เป็นได้

สเตตฟูลไฟร์วอลล์เป็นไฟร์วอลล์ที่ทำงานโดยที่สามารถเข้าใจสถานะของการสื่อสารทั้งกระบวนการ เพราะถือว่าการสื่อสารข้อมูลจะสมบูรณ์ได้นั้นต้องมีทั้งการส่งและการรับอย่างสอดคล้องสัมพันธ์กันนั่นเอง หมายถึงหากไฟร์วอลล์จะสามารถควบคุมการสื่อสารได้จริงก็จะต้องสามารถเข้าใจกระบวนการของการสื่อสารตั้งแต่ต้นจนจบ โดยทั่วไปเราจะเรียกไฟร์วอลล์แบบนี้ว่า “สเตตฟูลอินสเปกชันไฟร์วอลล์” (หรือเรียกย่อๆ ว่าสเตตฟูลไฟร์วอลล์) เป็นไฟร์วอลล์ที่ทำการควบคุมแพทเทรฟฟิกโดยใช้หลักการของแพ็กเก็ตฟิลด์เตอร์ริง และการกำหนดแอคเซสรูลเช่นเดียวกับสกรีนิงเราเตอร์แต่สเตตฟูลไฟร์วอลล์จะมีความสามารถในการวิเคราะห์และรับรู้ความต่อเนื่องของแพ็กเก็ตในโปรโตคอลในระดับที่สูงขึ้นไปมากกว่า ไม่ว่าจะเป็น ทีซีพี, เอฟทีพี, เอชทีทีพี หรือแม้กระทั่งโปรโตคอลในระดับแอปพลิเคชัน ที่จะมีการกำหนดสเตตของตนเอง อีกทั้งยังเป็นเครื่องมือที่ถูกออกแบบมาเพื่อทำหน้าที่ในการควบคุมแพทเทรฟฟิกโดยเฉพาะไม่ได้เป็นการดัดแปลงการทำงานมาจากเราเตอร์จึงมีความสามารถในการควบคุมแพทเทรฟฟิกการกำหนดแอคเซสรูล การบริการ รวมไปถึงความยืดหยุ่นของการควบคุมแพทเทรฟฟิก และประสิทธิภาพในการทำงานที่สูงกว่าสกรีนิงเราเตอร์เป็นอย่างมาก โดยทั่วไปหากพูดถึงไฟร์วอลล์จะหมายถึงไฟร์วอลล์ประเภทนี้เอง

ตามที่ได้กล่าวไว้ข้างต้นว่า ความแตกต่างที่สำคัญของไฟร์วอลล์ทั้งสองชนิดนี้ในแง่ของการตรวจสอบแพทเทรฟฟิกคือ สเตตฟูลไฟร์วอลล์ มีความสามารถในการวิเคราะห์แพทเทรฟฟิกที่ผ่านไปในโปรโตคอลที่เลเยอร์สูงขึ้นไปไม่ว่าจะเป็น ทีซีพี, ยูดีพี, ไอซีเอ็มพี ได้อย่างสมบูรณ์ต่างจาก สกรีนิงเราเตอร์ที่สามารถวิเคราะห์ได้เฉพาะเท่าที่จะมีข้อมูลใน 1 แพ็กเก็ตเท่านั้นเพราะบางครั้งแพทเทรฟฟิกที่อ่านไปมานั้นเชื่อมโยงกันหลายแพ็กเก็ต โดยเฉพาะ ทีซีพี ซึ่งจะมีลำดับของการติดต่อสื่อสารที่สัมพันธ์กันในแต่ละแพ็กเก็ต การพิจารณาแพ็กเก็ตใดแพ็กเก็ตหนึ่งโดยไม่พิจารณาแพ็กเก็ตอื่นที่เกี่ยวข้องก็จะไม่สามารถควบคุมแพทเทรฟฟิกของ ทีซีพี ได้นอกจากนี้ยังรวมไปถึงการที่สเตตฟูลไฟร์วอลล์มีความสามารถในการประกอบรวมแฟร็กเมนต์เข้าด้วยกันให้เป็นดาต้าแกรมที่สมบูรณ์ ก่อนหลังจากนั้นจึงนำดาต้าแกรมนั้นมาทำการตรวจสอบเปรียบเทียบกับแอคเซสรูล

นอกจากการเชื่อมโยงกันของหลายแพ็คเกจสำหรับแพ็คเกจโปรโตคอล ทีซีพี ในทรานสปอร์ตเลเยอร์แล้ว ในแอปพลิเคชันเลเยอร์ก็มีแอปพลิเคชันบางชนิดที่จะต้องอาศัยการพิจารณาแทรกฟิกันอย่างต่อเนื่องเพื่อที่จะนำมากำหนดเป็นแอคเชอรูล ยกตัวอย่างเช่น การทำงานของเอฟทีพีซึ่งในระหว่างการทำงานของแอปพลิเคชันนั้นโฮสที่เป็นไคลเอนต์จะสามารถกำหนดพอร์ตชั่วคราวขึ้นมาเป็นเซิร์ฟเวอร์พอร์ตใช้สำหรับรับ-ส่งไฟล์ได้ โดยพอร์ตเหล่านี้จะปิดลงเมื่อการรับ-ส่งข้อมูลเสร็จสิ้นสมบูรณ์ ซึ่งในกรณีนี้หากไม่มีการพิจารณาแทรกฟิกที่มีมาก่อนหน้าแล้วไฟร์วอลอาจจะถือได้ว่าการเปิดให้บริการใหม่ขึ้นมาได้ดังนั้นสเตรตฟูลไฟร์วอลจึงมีการทำงานที่ค่อนข้างใกล้ชิดกับแอปพลิเคชันได้ค่อนข้างดี เพราะแอปพลิเคชันที่ใช้งานอยู่ในเน็ตเวิร์กไม่ได้มีเฉพาะแอปพลิเคชันพื้นฐานเท่านั้น มีแอปพลิเคชันอื่นๆ อีกมาก แต่หากแอปพลิเคชันใดมีการใช้งานอย่างแพร่หลาย และเป็นที่ยอมรับของผู้ใช้ โดยส่วนใหญ่ผู้ผลิตจะใส่บิตชั่น การควบคุมแทรกฟิกสำเร็จรูปมาให้อยู่ในไฟร์วอลเลย

2.4.4 ข้อดีของสเตรตฟูลไฟร์วอล

1. ประสิทธิภาพในการทำงานสูง เนื่องจากออกแบบมาทำหน้าที่ไฟร์วอลโดยเฉพาะ สามารถรองรับแอคเชอรูลที่ซับซ้อนได้ โดยที่ความสามารถในการทำงานไม่ลดลง
2. มีคุณสมบัติเพิ่มเติมให้ใช้ได้มากนอกเหนือจากการควบคุมแทรกฟิก เช่นสามารถนำไปใช้ร่วมกับระบบการตรวจจับการบุกรุกหรือ IDS (Intrusion Detection System) เพื่อป้องกันการโจมตีได้อัตโนมติ, สามารถบันทึกข้อมูลเอาไว้กลับมาดูภายหลังได้, สามารถใช้งานร่วมกับระบบป้องกันไวรัสได้เป็นต้น
3. การกำหนดแอคเชอรูลทำได้ง่ายเพราะไฟร์วอลมีความเข้าใจในโปรโตคอลระดับสูง ดังนั้นผู้ใช้อาจจะไม่จำเป็นต้องมีความเชี่ยวชาญในเรื่องระบบเครือข่ายมากนัก ก็พอจะใช้งานไฟร์วอลได้โดยกำหนดกฎพื้นฐานของแอปพลิเคชันที่ผู้ใช้รู้จัก มากกว่าการกำหนดกฎโดยใช้ข้อมูลบนแพ็คเกจโดยตรง เช่นแทนที่จะต้องกำหนดแอคเชอรูลให้อนุญาต ICMP Time exceed in Transit ให้ผ่านได้เพื่อใช้คำสั่ง Traceroute (ซึ่งโดยทั่วไปแล้วผู้ใช้ไม่ทราบวโปรแกรมใดใช้โปรโตคอลอะไร แต่จะรู้ว่าตนเองต้องการใช้โปรแกรมหรือแอปพลิเคชันอะไรบ้าง) ก็ระบุในไฟร์วอลว่าอนุญาตให้คำสั่ง Traceroute ทำงานได้หลังจากนั้นไฟร์วอลจึงกำหนดเป็นแอคเชอรูลที่ระบุโปรโตคอลนั่นเอง
4. สามารถเพิ่มเติมความปลอดภัยโดยระบบการตรวจสอบผู้ใช้ (Authenticate) ได้
5. การสื่อสารระหว่างไฟร์วอลกับแอคมินคอลโซล (Administration Console: เครื่องที่ทำหน้าที่ในการบริหารไฟร์วอล) จะมีความปลอดภัยสูง มีการตรวจสอบสิทธิ์ของผู้ที่เป็นแอคมินรวมทั้ง

การสื่อสารระหว่างไฟร์วอลล์กับคอลโซลจะมีการรักษาความปลอดภัยที่เข้มงวด มีการเข้ารหัสเพื่อป้องกันการดักอ่านข้อมูล

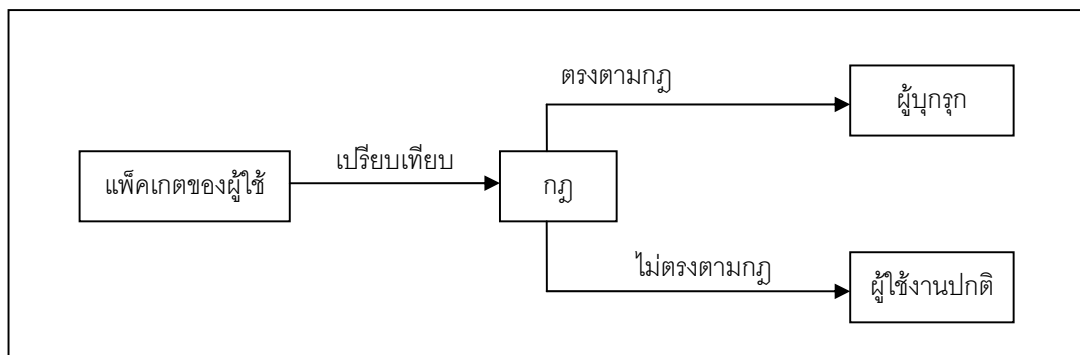
2.5 ระบบตรวจจับผู้บุกรุกระบบคอมพิวเตอร์

ระบบตรวจจับผู้บุกรุกระบบคอมพิวเตอร์ (IDS : Intrusion Detection System) คือ ระบบที่ทำหน้าที่ติดตามดูการทำงานที่เกิดขึ้นบนระบบเครือข่ายคอมพิวเตอร์ เพื่อค้นหาร่องรอยที่บ่งบอกว่ากำลังมีผู้บุกรุกเข้ามาในระบบ หรือทำการค้นหาการกระทำที่เกินขอบเขตสิทธิ์ของผู้ใช้ระบบ

ผู้ดูแลระบบบางคนอาจคิดว่าระบบที่ตนดูแลอยู่นั้นไม่ได้มีข้อมูลที่สำคัญอะไร ถึงแม้ว่าจะโดนบุกรุกก็คงได้ไม่เป็นไร จึงละเลยและไม่ใส่ใจดูแลความปลอดภัยของระบบคอมพิวเตอร์ที่อยู่ในความรับผิดชอบของตนมากนัก แต่ในความเป็นจริงแล้วผู้บุกรุกนั้นอาจไม่ได้มีจุดประสงค์เพียงแค่บุกรุกเพื่อเข้ามาขโมยข้อมูลเพียงอย่างเดียว หากแต่อาจมีจุดประสงค์ในการที่จะใช้ระบบคอมพิวเตอร์ของเราในการโจมตีระบบอื่นๆ ไปได้ และหากเป็นเช่นนั้น เมื่อมีการตรวจสอบจากระบบที่ถูกโจมตีกลับมาพบว่าการโจมตีนั้นๆ มาจากระบบของเราแล้ว ผู้ดูแลระบบจะต้องเป็นผู้รับผิดชอบความผิดดังกล่าวไม่ว่าจะเป็นความผิดเล็กน้อยหรือใหญ่หลวงเพียงใด อย่างหลีกเลี่ยงไม่ได้ ดังนั้นการรักษาความปลอดภัยของระบบของตนจึงเป็นสิ่งที่จำเป็นอย่างยิ่ง

2.5.1 รูปแบบของระบบตรวจจับผู้บุกรุกระบบคอมพิวเตอร์

วิธีเปรียบเทียบพฤติกรรมผู้ใช้กับวิธีการบุกรุกที่ระบบรู้จักเป็นวิธีการที่ระบบจะทำการเปรียบเทียบพฤติกรรมการใช้งานของผู้ใช้ว่าตรงกับรูปแบบการบุกรุกที่ระบบรู้จักหรือไม่ โดยระบบส่วนใหญ่จะใช้กฎ (Rule-based expert system) โดยตั้งกฎตามพฤติกรรมที่น่าสงสัยว่าจะเป็นการบุกรุก เช่น การตั้งกฎว่าเมื่อพบการเชื่อมต่อมายังพอร์ตหมายเลข 21 ซึ่งเป็นพอร์ตของบริการ FTP โดยใช้บัญชีผู้ใช้เป็น root เป็นต้น ซึ่งการทำเช่นนี้เข้าข่ายน่าสงสัย เพราะโดยปกติแล้วบัญชีผู้ใช้นี้มักจะถูกปิดการใช้งานไว้



รูปที่ 2.1 แสดงการทำงานของระบบตรวจจับผู้บุกรุก

จากรูปแพ็คเกจที่มาจากการใช้งานเครือข่ายของผู้ใช้ต่างๆ จะถูกนำมาเปรียบเทียบกับกฎของระบบตรวจจับผู้บุกรุกถ้าตรงกับกฎก็จะถือว่าผู้ใช้นั้นเข้าข่ายเป็นผู้บุกรุกระบบ แต่ถ้าไม่ตรงกับกฎก็จะถือว่าเป็นผู้ใช้ปกติสามารถทำงานในระบบได้ต่อไปตามปกติ

2.5.2 จุดอ่อนของวิธีการเปรียบเทียบพฤติกรรมผู้ใช้นับวิธีการบุกรุกที่ระบบรู้จักนั้นคือ

1. ประสิทธิภาพในการตรวจจับผู้บุกรุกนั้นจะขึ้นอยู่กับทางเลือกใช้กฎที่ใช้เปรียบเทียบ
2. หากตั้งกฎได้ไม่ดีคลุมพอ เมื่อผู้ใช้ปกติทำพฤติกรรมที่ตรงกับกฎของระบบตรวจจับผู้บุกรุกโดยไม่ได้ตั้งใจระบบตรวจจับอาจเข้าใจผิดว่าผู้ใช้นั้นๆ เป็นผู้บุกรุกได้
3. รูปแบบการบุกรุกที่ไม่รู้จักจะไม่สามารถถูกตรวจพบได้